

ICDFA Security Policy Manual

Principles of Information Security Governance

Full Name	MERCY RACHAEL AJAYI
Registration Number	C11/26/CGRCE/17219
Cohort / Batch	CGRCE Cohort 11
Course Title	Information Security Governance
Date Submitted	25 September, 2026

Supporting analysis workbook: [GRC102 W3 ANALYSIS - MERCY AJAYI C11-26-CGRCE-17219.xlsx](#)

Table of Contents

Executive Summary	2
Introduction	2
Part A: Cross-Functional Governance Responsibility Model	3
A1. Governance Roles and Responsibilities	3
A2. RACI Matrix	6
A3. Segregation of Duties and Conflict Resolution	8
A4. Material Cyber Risk Escalation Path	10
A5. Cross Functional Failure Scenario	13
Part B: The CISO, Board and Contemporary Governance	15
How the CISO Role Has Evolved	15
CISO Reporting Lines and Board Access	15
Regulatory Scrutiny and Executive Accountability	16
Public Example: Uber and Joseph Sullivan	16
Recommended CISO Governance Model	17
Part C: Major Security Breach Governance Case Study	18
Change Healthcare Cyberattack, 2024	18
C1. Incident overview and business impact	18
C2. Governance, accountability and risk arrangements before the incident	18
C3. Governance weaknesses	19
C4. Roles of the Board, executives, security function and business units	20
C5. Regulatory, legal, financial and reputational consequences	21
C6. Recommended governance improvements	22
Part D: NDPC Data Analysis and GRC Application	24
D1. Required Core Analysis	24
D2. Advanced Governance Analysis	31
D3. Three CISO and Board Insights	36
Conclusion	38
References	39

Executive Summary

I was appointed Lead Security Governance Adviser to a large, fast growing organisation where security decisions were still being treated mainly as an IT responsibility. This is risky because when a cyber incident happens, it can quickly affect other areas such as Legal, Finance, HR and Risk. This report presents a governance model that clearly defines who is responsible for security decisions and activities. It also tests the model using research, a real life cyberattack and a simulated incident dataset.

Part A defines eight governance roles, a RACI matrix covering eleven activities with one accountable owner for each, five segregation of duties conflicts with practical controls, and a four stage escalation path with clear timelines. **Part B** looks at how the CISO role has changed, why reporting lines are important, and recommends a structure where the CISO reports to the CEO and has direct access to the Board. **Part C** examines the February 2024 Change Healthcare cyberattack and separates information that is publicly available from my own analysis. **Part D** analyses 180 simulated NDPC incidents.

The data shows that Insider Threat is less common but has the highest average cost at \$138,506. It also shows that Critical and High incidents are more likely to miss their SLA targets, with 12 of 17 closed Critical incidents and 25 of 34 closed High incidents breaching their targets. In addition, 25.56% of the incidents are still open or in progress. Identity and Access Management had the highest number of incidents and the highest total cost among the control domains. Based on these findings, three actions are recommended, each with a clear owner and a measure that the Board can use to track progress.

Introduction

This assignment looks at security governance from the perspective of the whole organisation, not just IT. Effective governance requires clear ownership and accountability. The Board and management need to have a clear view of important cyber risks, while departments such as Legal, Finance, HR, Risk and IT need to understand their roles and responsibilities.

The report follows the four parts of the brief. Part A develops a cross-functional responsibility model. Part B looks at the role of the CISO and the Board using published frameworks, regulations and a documented case. Part C examines the Change Healthcare breach from a security governance perspective. Part D uses the simulated NDPC dataset to identify key findings and make evidence-based recommendations. External sources are cited and included in the References.

Part A: Cross-Functional Governance Responsibility Model

Effective security governance requires clear roles and responsibilities across the organisation. Cybersecurity should not be treated as only an IT responsibility because security decisions can also affect areas such as finance, legal, HR and enterprise risk. In this section, I define the responsibilities of eight key roles and explain how they should work together.

A1. Governance Roles and Responsibilities

- **Board of Directors / Board Risk Committee**

Decision Authority: Approves the organisation's security strategy, risk appetite and major cyber risk acceptance. It also has final authority for Board-level escalation.

Accountability: Provides oversight of cyber risk and ensures that management has appropriate controls and that major regulatory responsibilities are being addressed.

Consultation: Consults the CEO, CISO, CRO and Legal on material cyber risks and may involve external auditors where necessary.

Reporting Expectations: Receives quarterly cyber risk reports from the CISO and CRO. Critical or Board-level incidents should be escalated within the agreed reporting timeframe.

Relationship to Others: Oversees the CEO and provides challenge and oversight to management. It also holds the CRO accountable for ensuring that cyber risk is included in the wider enterprise risk framework.

- **Chief Executive Officer (CEO)**

Decision Authority: Approves major security priorities and resource allocation within delegated authority. The CEO also delegates operational responsibilities to the appropriate security and technology leaders.

Accountability: Accountable for ensuring that the governance model is implemented and that the organisation has the resources needed to manage cyber risk.

Consultation: Consults the Board, CISO, CRO, Legal, Finance and HR when making major security and risk decisions.

Reporting Expectations: Receives regular updates from the CISO and escalates material cyber risks to the Board.

Relationship to Others: Coordinates the work of the CISO and CRO and ensures that functions such as IT, HR, Legal and Finance work together on cyber risk.

- **Chief Information Security Officer (CISO)**

Decision Authority: Defines security policies, standards and control requirements and has the authority to escalate material security risks to the CEO and Board.

Accountability: Accountable for the effectiveness of the security programme, security governance and coordination of major incident response.

Consultation: Works with IT, Legal, Risk, HR and relevant business units when developing policies and making security and risk decisions.

Reporting Expectations: Provides regular security and risk reports to the CEO and has direct access to the Board when material issues need to be escalated.

Relationship to Others: Works with the CRO on cyber risk, Legal on regulatory and privacy issues, HR on awareness and employee-related security matters, and IT on the implementation of security controls.

- **Chief Risk Officer (CRO) / Enterprise Risk Function**

Decision Authority: Ensures cyber risk is included in the enterprise risk register and can challenge risk assessments and acceptance decisions.

Accountability: Accountable for maintaining the enterprise risk framework and ensuring that cyber risk is assessed and monitored consistently with other business risks.

Consultation: Consults the CISO, Legal, Finance and relevant business leaders when assessing and reporting cyber risk.

Reporting Expectations: Reports the overall enterprise risk profile to the CEO and Board Risk Committee, including significant cyber risks.

Relationship to Others: Works closely with the CISO while maintaining an independent risk perspective that can be presented to management and the Board.

- **Legal / Privacy / Compliance**

Decision Authority: Provides advice on regulatory and legal obligations, including privacy and breach notification requirements.

Accountability: Accountable for legal and regulatory advice, contractual requirements and supporting timely regulatory notifications where required.

Consultation: Consulted on incidents involving personal data, regulatory exposure, third-party contracts and security policies with legal implications.

Reporting Expectations: Reports significant legal and regulatory risks to the appropriate management and Board committees and keeps the CISO informed about relevant regulatory requirements.

Relationship to Others: Works with the CISO during incidents, HR on employee-related matters and Finance on contractual and financial risks.

- **Finance**

Decision Authority: Approves financial allocations within its delegated authority and reviews the financial impact of security controls and cyber incidents.

Accountability: Accountable for security-related financial planning, insurance considerations and accurate reporting of incident costs.

Consultation: Consulted on security budgets, major control investments, third-party risk decisions and the financial impact of cyber incidents.

Reporting Expectations: Reports relevant security spending and incident costs to the CEO and appropriate Board committees.

Relationship to Others: Works with the CISO on security budgeting, Legal on contractual matters and IT on technology procurement.

- **Human Resources (HR)**

Decision Authority: Manages employee-related security processes such as awareness training, background checks and disciplinary procedures, in line with organisational policy and applicable requirements.

Accountability: Accountable for staff security awareness and ensuring that joiner, mover and leaver processes are properly followed.

Consultation: Consulted on insider threat matters, employee awareness, disciplinary actions and roles involving privileged access.

Reporting Expectations: Reports relevant training and employee security indicators to the CISO and Legal.

Relationship to Others: Works with IT on access removal, the CISO on security awareness and Legal on employment and disciplinary matters.

- **Information Technology / Technology Operations**

Decision Authority: Implements and operates technical controls in line with approved security policies and standards.

Accountability: Accountable for areas such as secure system configuration, patching, identity management operations and technology resilience.

Consultation: Consulted on the technical feasibility, operational impact and implementation of security controls.

Reporting Expectations: Reports operational security metrics, patching status, system issues and availability information to the CISO.

Relationship to Others: Implements security controls defined through the governance process and works with HR and other functions on areas such as access management and employee changes.

A2. RACI Matrix

I used a RACI matrix to show who is responsible for each major governance activity. R means Responsible, which is the role that does the work. A means Accountable, which is the role that owns the final decision or outcome. C means Consulted, while I means Informed. Each activity has only one Accountable role. When the same role is both Responsible and Accountable, it is shown as A/R.

The matrix covers eleven activities, including the ten required in the brief. I separated security awareness from disciplinary action because different roles are responsible and accountable for each one.

Governance Activity	Board	CEO	CISO	CRO	Legal	Finance	HR	IT
Security strategy approval	A	R	R	C	C	C	I	C
Enterprise cyber-risk acceptance	A	R	R	R	C	C	I	C
Information security policy approval	I	A	R	C	C	I	C	C
Major incident response governance	I	A	R	C	R	C	C	R
Regulatory breach notification	I	C	R	C	A/R	I	I	C
Privileged access approval	I	I	A	C	I	I	C	R
Third-party cyber-risk acceptance	I	A	R	C	R	C	I	C

Security awareness and disciplinary action	I	I	A	I	C	I	R	C
Cybersecurity budget prioritisation	C	A	R	C	I	R	I	C
Disciplinary action for security violations	I	I	C	I	C	I	A/R	R
Board cyber-risk reporting	I	C	A/R	R	C	C	I	C

Some of these choices required judgement, so I have explained the reasoning behind them below:

- **Risk acceptance.** The Board is accountable for accepting enterprise cyber risk because it sets the organisation's risk appetite. The CEO can make decisions within the limits delegated by the Board, while risks above those limits are referred to the Board (see A4).
- **Regulatory breach notification.** Legal is accountable because it handles the legal position and requirements. The CISO provides the technical information needed, while the CEO is consulted before the notification is made.
- **Board reporting.** The CISO is accountable for the content of cyber risk reports sent to the Board. The CEO is consulted but is not accountable. This helps ensure that the information reaching the Board is not filtered by management.
- **Privileged access.** The CISO is accountable for the overall process, but approval of privileged accounts within the Security team is handled by a separate approver (see A3, conflict 1).

The point of the matrix is to separate doing the work from owning the decision. IT can implement a control without also deciding whether the organisation accepts the risk that control leaves behind.

A3. Segregation of Duties and Conflict Resolution

Segregation of duties means that one person or team should not control every stage of an important process. I identified five conflicts that could realistically happen under the governance model above. For each one, I suggested a simple control that provides enough protection without making the process unnecessarily slow or difficult.

1. Privileged Access Creation and Approval

Requesting, approving and reviewing. An administrator, or the CISO when it involves the Security team, could end up approving their own access.

Why it is risky: This creates a fraud and governance risk because someone who can create and approve their own privileged account could give themselves access without anyone independently checking whether it is actually needed.

Practical control: The CISO remains responsible for the overall process, but approval for Security team accounts should be handled by a separate designated approver, such as someone from Risk or IT. All requests should be logged in the IAM system and reviewed quarterly, with occasional independent audit checks.

2. Vendor Selection and Third Party Risk Acceptance

The business owner who wants to use the vendor also accepts the cyber risk.

Why it is risky: This creates compliance and operational risk because the pressure to onboard the vendor quickly may cause security weaknesses to be overlooked. There is also no independent review from someone with a different responsibility.

Practical control: A separate Security and Risk review should be completed before any material cyber risk is accepted. The business owner can handle the commercial decision, while Risk and Security assess the cyber risk based on the organisation's risk appetite. The review should also have a fixed turnaround time, such as ten working days, so that security checks do not unnecessarily delay projects.

3. Security Incident Investigation and Closure

The team that responds to an incident also decides when the incident is closed.

Why it is risky: This creates an operational risk because the team may close an incident once the immediate problem appears to be resolved, while the root cause remains. This could lead to the same issue happening again.

Practical control: The CISO or Risk function should approve the closure of High and Critical incidents using a short evidence checklist. This should confirm that the root cause has been

identified, corrective actions have been completed or assigned to an owner, and lessons learned have been recorded.

4. Disciplinary Action and Technical Investigation

HR may take action on a security case while Security or IT is still investigating the incident.

Why it is risky: This creates compliance and legal risks because evidence could be lost, the employee may still have access during the investigation, and employment law or privacy requirements may be overlooked.

Practical control: Security should document the violation and make sure the evidence is preserved. Legal should provide advice before HR finalises any disciplinary action. IT should remove the employee's access when the agreed trigger is reached. Each function's role should be clearly defined before an incident occurs.

5. IT Control Implementation and Effectiveness Measurement

IT implements a control and also reports on how effective it is.

Why it is risky: This creates a governance risk because the team assessing the control is also the team that implemented it. This could make it harder to identify or report failures accurately.

Practical control: IT should implement the control, while the CISO or GRC function independently tests its effectiveness. Where possible, compliance information should come from automated dashboards that the team being assessed cannot edit.

A4. Material Cyber Risk Escalation Path

A material cyber risk is an issue that could lead to significant financial loss, regulatory action, disruption of important services or serious reputational damage. The escalation path below is designed to move the issue from detection to the right decision maker, with a clear owner and deadline at each stage.

Trigger Criteria

- An issue enters the escalation path when any of the following applies:
- A Critical or High incident with an estimated cost impact above \$75,000.
- A suspected data breach or data exfiltration involving sensitive or personal information.
- Ransomware, a critical system compromise or an insider threat involving access to important data.
- Significant regulatory exposure, especially where personal or financial data is involved.
- A High severity incident involving a third party.
- A Critical incident that has already breached or is close to breaching its SLA.
- Any incident that may require notification to the Board or a regulator.

I chose the \$75,000 threshold based on the NDPC data. The average incident cost is \$57,186. Out of the 180 incidents, 49, or 27.2%, cost more than \$75,000. These incidents also account for 49.7% of the total cost impact. This means the threshold would flag about one in four incidents while still capturing roughly half of the financial exposure.

Escalation Workflow

Step 1: Operational Detection, 0 to 1 hour

The SOC or IT Security team detects and records the incident. The responsible SOC analyst opens an incident ticket, records the initial severity and preserves the available evidence. The relevant team lead is also notified.

Low or Medium incidents that do not involve regulatory exposure can normally remain at the operational level and follow the agreed SLA of 30 days for Low and 14 days for Medium.

Step 2: CISO Review, 1 to 4 hours

If the trigger criteria are met, the SOC Lead escalates the issue to the CISO or delegated security lead. The initial review should consider the affected systems, possible data exposure, business impact, control failure, regulatory exposure and estimated cost.

For High incidents, the CISO review should take place within 4 hours. For Critical incidents, it should happen within 1 hour. The CISO then decides whether the issue needs to be escalated to executive management.

Step 3: Executive Review, 4 to 24 hours

For material incidents, the CISO escalates the issue to the CEO and CRO. Legal and Finance are consulted where the incident has regulatory or financial implications.

The information provided should include the business impact, third party involvement, containment status and regulatory assessment. The CEO can decide whether the risk should be accepted or mitigated within delegated authority. If the risk is outside that authority, it is escalated to the Board.

High incidents should reach the executive level within 24 hours, while Critical incidents should be escalated within 4 hours.

Step 4: Board Review, 24 to 72 hours

Board level incidents are escalated through the CEO to the Board or relevant Board Risk Committee. The report should contain the incident details, financial impact, regulatory assessment, containment and recovery status, remediation plan and lessons learned.

Where the remaining risk is outside management's delegated authority, the Board or relevant committee makes the final risk acceptance decision. This is especially important for Critical incidents involving major regulatory exposure or significant financial impact.

Evidence Required for Escalation

The information passed through each stage should be clear enough for the next decision maker to understand the situation. This should include:

- Incident timeline
- Affected systems and information
- Current severity
- Business and financial impact
- Regulatory assessment
- Actions already taken
- Containment and recovery status
- Outstanding risk
- Decision required

Escalation Timing

The escalation times are linked to the severity of the incident and the SLA targets used in the NDPC dataset:

Severity	Operational SLA	Escalation Expectation
Low	30 days	Operational level
Medium	14 days	Operational level unless a material trigger exists
High	7 days	Executive review within 24 hours
Critical	3 days	Immediate escalation, with executive review within 4 hours and Board review where required

This approach helps ensure that material cyber risks do not remain at the operational level when they require management or Board attention. It also makes the escalation process easier to follow because each stage has a clear owner, timeframe and decision point.

A5. Cross Functional Failure Scenario

Scenario

An employee in the Finance department is terminated for a policy violation. HR processes the termination, but IT is not informed on time because there is no automated joiner-mover-leaver process. As a result, the employee still has privileged access to a finance system and later logs in remotely and downloads customer financial data.

The SOC detects unusual data transfer but assumes that it may be normal Finance activity and does not escalate the issue to Legal. Legal only becomes aware of the incident two weeks later after a customer complaint. Finance was also not involved early enough to plan for the cost of forensic investigation. At the same time, the Risk team had previously accepted the risk of delayed access removal as low because there was not enough data to show the actual impact of the delay.

This situation shows how a security incident can become worse when departments do not share information at the right time. IT may focus on the technical issue, while Legal, Risk, Finance and HR are left without the information they need to respond properly. This can lead to regulatory exposure involving financial data, contractual problems, financial losses and reputational damage.

Why the Failure Happened

The main problems in the scenario are:

- **HR and IT were not properly coordinated:** There was no automated process to trigger access removal when an employee was terminated.
- **SOC and Legal were not properly coordinated:** There was no clear trigger telling the SOC when a potential privacy or financial data incident must be escalated.
- **Finance was not involved early:** The organisation had not planned for the financial cost of forensic investigation.
- **Risk acceptance was not supported by enough evidence:** The risk of delayed access removal had been accepted without reliable data about how often delays occurred or what they could cost.
- **The CISO had limited visibility:** The CISO did not have enough visibility into the HR access removal process to identify the governance gap before the incident.

Recommendations

1. Implement an automated IAM workflow

HR termination records should trigger an automatic request to the IT or IAM team to remove the employee's access. The target should be access removal within 2 hours of the termination decision.

Owner: HR and IT

Success measure: 100 percent of terminated employees have their access removed within 2 hours, measured monthly.

2. Create a cross functional incident playbook

The organisation should clearly define when the SOC must involve Legal. This should include incidents involving privacy, financial data or employment data.

Owner: CISO and Legal

Success measure: 100 percent of relevant incidents have Legal consulted within 4 hours.

3. Hold a monthly security governance meeting

The CISO, CRO, Legal, Finance, HR and IT should meet regularly to review open incidents, SLA breaches and identified control gaps. Actions should have named owners and deadlines.

Owner: CISO

Success measure: At least 90 percent of agreed actions are completed within the required timeframe.

4. Pre-approve an incident response retainer

Finance and the CISO should arrange an annual retainer with a forensic investigation provider. This would reduce delays caused by having to find and approve funding during an active incident.

Owner: Finance and CISO

Success measure: An active retainer is in place and tested at least once each year.

5. Use incident data when accepting risk

The CRO should use available incident data, such as resolution times, costs and access removal delays, when deciding whether to accept a security risk. Risk acceptance should be supported by evidence rather than assumptions.

Owner: CRO

Success measure: All relevant risk acceptance decisions have supporting data attached.

Overall, this scenario shows that a technical security issue can become a wider governance problem when departments work separately. Clear escalation rules, shared information and defined ownership would help the organisation respond earlier and make better decisions.

Part B: The CISO, Board and Contemporary Governance

In this part, I looked at how the CISO role has changed over the last decade, why the CISO's reporting line matters, and how Boards and regulators are becoming more involved in cybersecurity governance. I used framework documents, regulatory publications and a real case to understand how the role has moved beyond technical security.

How the CISO Role Has Evolved

The CISO role has changed because cybersecurity is now closely connected to business operations, regulatory requirements and enterprise risk. In the past, the role was mostly seen as a technical position within IT, with responsibilities such as firewalls, antivirus, access control and compliance. Today, the CISO is expected to understand how security risks can affect the wider organisation and communicate these risks to senior management and the Board.

One example of this change is the NIST Cybersecurity Framework 2.0, released in 2024. The framework introduced the Govern function, which covers cybersecurity strategy, roles, responsibilities, policies and oversight. This shows that cybersecurity is being treated as part of wider organisational risk management and not just as a technical responsibility (National Institute of Standards and Technology, 2024).

ISO/IEC 27001:2022 also places importance on leadership and clearly assigned security responsibilities and authorities (International Organization for Standardization, 2022). From my understanding, this means that a CISO needs more than technical knowledge. The role also requires good communication, risk management skills and an understanding of business and regulatory requirements.

Reporting lines also show how the role is changing. Heidrick & Struggles reported that 8 percent of the CISOs surveyed reported directly to the CEO in 2022. In its 2025 survey, this had increased to 42 percent, while 30 percent reported to a CIO or CTO (Heidrick & Struggles, 2022; Heidrick & Struggles, 2025). The surveys used different samples, so I see these figures as showing the direction the role is moving rather than treating them as a direct trend. Overall, technical knowledge is still important, but skills such as risk judgement, communicating with the Board and understanding regulatory requirements have also become important parts of the CISO role.

CISO Reporting Lines and Board Access

A CISO who reports through IT may face a conflict because IT is usually focused on delivering projects and keeping systems available, while the CISO may sometimes need to slow down a project because of security concerns. If the CISO's objectives and budget depend on the CIO, there is also a risk that security concerns may be reduced before they reach senior management.

For a large organisation, I would have the CISO report directly to the CEO and have a standing right to speak to the Board or its Risk or Audit Committee without needing approval from anyone in between.

Independence also depends on the CRO providing a separate challenge and the CISO owning the content of the Board report so that the message is not changed before it reaches the Board. A practical reporting cycle would be monthly reporting to management, quarterly reporting to the Board committee and immediate escalation of material incidents. The reports should focus on information that helps with decision making, including the main risks, control performance, incidents, regulatory issues, third party exposure, security spending and overdue remediation.

Regulatory Scrutiny and Executive Accountability

Regulators have also made cybersecurity accountability more formal. In 2023, the US Securities and Exchange Commission introduced rules requiring listed companies to disclose material cybersecurity incidents and provide information about their cyber risk management, strategy and governance, including the role of the Board and management (US Securities and Exchange Commission, 2023). In Nigeria, the Nigeria Data Protection Act 2023 also places responsibilities on data controllers and processors, including breach notification requirements. This means that legal and regulatory considerations are now part of security decisions as well (Federal Republic of Nigeria, 2023).

The CISO therefore needs to be able to explain technical findings in terms that the wider business can understand. This includes explaining which services are exposed, what could happen if a control fails, what security measures need funding and which risks management has decided to accept. Simply giving the Board a number of open vulnerabilities does not give them enough information to make these decisions.

The organisation's dependence on digital services has also expanded the CISO's role. When payments, patient records or customer platforms depend on digital systems, an outage can quickly become a business problem. The CISO therefore has a role in resilience and recovery, not just prevention. The role also involves helping management understand how long the organisation can continue operating without an important service. Part C shows how this can happen in a real situation.

Public Example: Uber and Joseph Sullivan

A real example that helped me understand the importance of CISO leadership is the case of Joseph Sullivan, the former Chief Security Officer of Uber. In 2016, hackers accessed data relating to about 57 million Uber users and drivers. In 2022, a federal jury found Sullivan guilty of obstructing an FTC proceeding and misprision of a felony in connection with his handling of the breach. He was later sentenced to three years of probation and fined \$50,000 (US Department of Justice, 2022a; US Department of Justice, 2023).

Uber later entered into a non prosecution agreement with the US Department of Justice in 2022. The agreement states that the hackers were paid through Uber's bug bounty programme. It also records that new management investigated and disclosed the breach after taking over in late 2017, and that Uber later changed the structure of its compliance, legal and security functions (US Department of Justice, 2022b).

From this case, my main takeaway is that the CISO needs a clear responsibility and a protected way to escalate serious security issues to Legal, the CEO and the Board. This reduces the risk of one person's judgement becoming the only safeguard when dealing with a major security incident.

Recommended CISO Governance Model

For a large organisation, I recommend that the CISO reports directly to the CEO and has a direct line to the Board Risk or Audit Committee. The CISO should also have a private session with the committee at least once a year. The CRO can provide an independent challenge through the enterprise risk process, while the Board sets the organisation's risk appetite and makes decisions on risks that are beyond management's authority. Legal, Finance, HR and IT would keep the roles assigned to them in the Part A RACI.

I would divide the security function into Governance, Risk and Compliance, Security Operations and Security Architecture. This would help keep control assessment separate from control operation, which addresses the conflict I identified in A3. I chose this structure because it addresses two issues that come up in the evidence: security risks being influenced by operational priorities and escalation depending too much on one person. It also fits with the Govern function in NIST CSF 2.0.

Part C: Major Security Breach Governance Case Study

Change Healthcare Cyberattack, 2024

I chose the February 2024 Change Healthcare cyberattack because it shows how one cyber incident can quickly become a business, healthcare, regulatory and governance problem. Change Healthcare is a major claims and payment intermediary owned by UnitedHealth Group (UHG). Because so many healthcare providers depended on its services, the disruption affected them as well.

How I separate fact from analysis. Points marked **Established** are based on company filings, Congressional testimony or regulator publications. Points marked **Analysis** are my own interpretation of the information. I have not presented these interpretations as facts about what UHG knew or decided because much of its internal governance information is not publicly available.

C1. Incident overview and business impact

Established: On 21 February 2024, UHG reported a cyberattack on Change Healthcare and said that it had isolated the affected systems (UnitedHealth Group, 2024). Change Healthcare processes about \$1.5 trillion in medical claims each year. After its systems were disconnected, healthcare providers could not verify insurance coverage, submit claims or receive payments (U.S. Senate Committee on Finance, 2024a).

Established: UHG's annual report states that it spent \$2.2 billion on direct response costs in 2024 and that Optum Insight experienced an estimated \$867 million in business disruption impacts. UHG also provided more than \$9 billion in interest free loans to healthcare providers and estimated that about 190 million individuals were affected by the breach (UnitedHealth Group, 2025). The U.S. Department of Health and Human Services Office for Civil Rights (OCR) also became involved by publishing guidance on HIPAA obligations and investigating the incident.

Analysis: These figures show why I see this as a governance issue and not only a technical one. A large part of the impact involved business continuity, customer support, financial support and privacy. These are areas that need to be considered by management before an incident happens.

C2. Governance, accountability and risk arrangements before the incident

Established: Change Healthcare became part of UHG through an acquisition completed in October 2022 (UnitedHealth Group, 2022). In written responses to the Senate Finance Committee, UHG's CEO said that the company had started bringing the acquired environment in

line with UHG's security standards, while some older infrastructure was still being integrated (U.S. Senate Committee on Finance, 2024c). The same responses state that cybersecurity is a standing item for the Board's Audit and Finance Committee and that Mandiant now advises the committee.

Analysis: The public information does not show UHG's risk register, the CISO's reporting line or how the Board challenged cybersecurity risks before the attack. Because of this, I have limited my conclusions to what the available evidence supports.

C3. Governance weaknesses

1. Multi-factor authentication was not enforced on an exposed server

Established: UHG's CEO told the Senate Finance Committee that the first server compromised in the attack did not have multi-factor authentication (U.S. Senate Committee on Finance, 2024a).

Analysis: I see this as an enforcement gap. The security requirement may have existed, but it was not being enforced on an externally accessible system. From a governance perspective, having a control in a policy is not enough. There also needs to be a way to check that the control is actually being applied.

2. Legacy technology inherited through an acquisition

Established: The CEO's written responses describe older infrastructure that was still being integrated into UHG's security standards (U.S. Senate Committee on Finance, 2024c).

Analysis: From my understanding, security gaps in an acquired company should be treated as formal enterprise risks, with a named owner, a deadline and reporting to senior management until they are resolved. I cannot confirm from the public information whether this was done in this case.

3. Concentration and continuity risk

Established: Change Healthcare was described at the Senate hearing as the nation's largest healthcare clearinghouse (U.S. Senate Committee on Finance, 2024a). The Committee Chair also stated that Change's exclusive contracts meant that more than a third of providers could not switch to another clearinghouse while its systems were unavailable (U.S. Senate Committee on Finance, 2024d). This was his statement at the hearing and not a finding by a regulator.

Analysis: When many organisations depend on one service, the service becomes a major point of failure. Governance should identify these dependencies and consider what would happen if the service was unavailable for several days.

4. Board level security expertise and independent challenge

Established: In his opening statement, the Committee Chair said that UHG had identified one Board member when asked which directors had cybersecurity expertise (U.S. Senate Committee on Finance, 2024d). In its written responses, UHG's CEO also said that Mandiant now advises the Board's Audit and Finance Committee (U.S. Senate Committee on Finance, 2024c).

Analysis: The first point is the Committee Chair's account, while the second describes a measure taken after the incident. Neither should be treated as a formal finding. However, the information shows that independent security advice was added at Board level after the attack. I cannot say from the public record how effective Board oversight was before the incident.

5. Recovery and resilience planning

Established: UHG disconnected Change Healthcare's systems to contain the attack, and the Committee Chair stated that some key functions were still not restored six weeks later (U.S. Senate Committee on Finance, 2024d). He also described the recovery plans as inadequate, which was his assessment.

Analysis: This suggests that the recovery arrangements may not have fully prepared for the loss of such a critical service. The public record does not show whether the issue was the design of the recovery plans, the testing of those plans or the scale of the attack. What is clear is that the disruption lasted long enough to create significant problems for customers and healthcare providers.

6. Ownership of breach notification

Established: OCR's guidance states that organisations affected by the Change Healthcare breach could delegate their HIPAA breach notifications to Change Healthcare. It also explained that only one entity needed to notify affected individuals, HHS and, where applicable, the media (U.S. Department of Health and Human Services, Office for Civil Rights, 2024).

Analysis: Because many organisations were affected by the same incident, notification responsibilities became an important issue during the response. In my view, these responsibilities should already be clear in contracts and incident response plans, with Legal and Privacy involved from the beginning of a major incident.

C4. Roles of the Board, executives, security function and business units

Board. Established: Cybersecurity is a standing item for the Board's Audit and Finance Committee (U.S. Senate Committee on Finance, 2024c). **Analysis:** The public information shows what the company changed after the incident, but it does not give enough information to determine how the committee challenged cybersecurity risks before the attack.

CEO and executive leadership. Established: The CEO testified before the Senate Finance Committee on 1 May 2024, apologised for the incident and said the company was still trying to understand why the compromised server did not have multi factor authentication (U.S. Senate Committee on Finance, 2024a, 2024b). **Analysis:** The CEO's testimony shows that accountability reached senior management. However, the uncertainty around the MFA control also shows why ownership of important security controls needs to be clearly defined.

CISO and security function. I could not find enough public information about specific decisions made by UHG's CISO or security team during this incident. I therefore do not make claims about their performance. This is one of the limits of using a public case study.

Business units, Legal and Finance. Established: UHG provided interest free loans to affected healthcare providers (UnitedHealth Group, 2025), while OCR published guidance on breach notification (U.S. Department of Health and Human Services, Office for Civil Rights, 2024). **Analysis:** The response involved finance, legal, privacy and customer facing teams, which supports the idea that a major cyber incident should be treated as an organisation wide issue rather than only an IT or security problem.

C5. Regulatory, legal, financial and reputational consequences

- **Regulatory and legal (established):** OCR issued guidance and opened an investigation under HIPAA, while the Senate Finance Committee held a hearing where the CEO testified (U.S. Department of Health and Human Services, Office for Civil Rights, 2024; U.S. Senate Committee on Finance, 2024a).
- **Financial (established):** UHG reported \$2.2 billion in direct response costs, \$867 million in business disruption impacts and more than \$9 billion in interest-free loans to providers in 2024 (UnitedHealth Group, 2025).
- **Privacy (established):** UHG estimated that about 190 million individuals were affected by the cyberattack (UnitedHealth Group, 2025).
- **Reputational (analysis):** UHG's CEO publicly apologised and faced sustained questioning from lawmakers during the Senate hearing. I consider this an indication of reputational impact, although I have not tried to measure the size of that impact.

C6. Recommended governance improvements

Improvement	Addresses	Owner	Measure
Make MFA mandatory on every externally accessible system. Any exception should have documented risk acceptance, a named owner and an expiry date.	Weakness 1	CISO, with IT	100% of external systems covered and zero exceptions past their expiry date.
Treat security gaps inherited from acquisitions as formal enterprise risks, with an owner, deadline and regular executive reporting.	Weakness 2	CRO and CISO	All acquisition-related gaps entered into the risk register within 30 days of closing.
Map critical services to their technology and third-party dependencies, and test alternative arrangements for a multi-day outage.	Weaknesses 3, 5	CRO and IT	Dependency map completed and at least one tested failover exercise for each critical service every year.
Give the CISO regular direct access to the Board committee and make sure the committee has independent security expertise.	Weakness 4	Board Chair and CEO	Quarterly CISO sessions held and at least one Board member or adviser with security expertise.
Agree in contracts and incident playbooks who is responsible for notifying whom, with Legal and Privacy involved in the incident response group from the start.	Weakness 6	Legal and CISO	Notification responsibilities agreed with all critical customers.
Run realistic recovery exercises covering long outages, payment	Weakness 5	CISO and business owners	At least one Board-level exercise each year, with findings tracked until

disruption, data compromise and regulatory responsibilities.			they are closed.
--	--	--	------------------

The Change Healthcare incident shows that cybersecurity governance is about more than just stopping an attack. It also involves making sure security controls are actually enforced, dependencies are understood, responsibilities are clear and the organisation can continue operating when something goes wrong. The CISO, Board, Risk, Legal, Finance, IT and business units all have a role to play in this.

Part D: NDPC Data Analysis and GRC Application

The NDPC workbook contains a simulated dataset of 180 incident records covering January 2024 to December 2025. I carried out the calculations in the accompanying workbook, using COUNTIF, SUMIF, AVERAGEIF and COUNTIFS formulas on the Incident_Data sheet. The charts in this report were also created from the same results. I kept the original Incident_ID values so that each result can be traced back to the relevant source rows in Appendix A. Since the data is simulated, the findings only apply to this exercise and do not represent a real organisation.

Two definitions are important when looking at the SLA results. **Breach rate (all)** is the number of breached incidents divided by all incidents in the group. **Breach rate (closed only)** uses only incidents with a final outcome, since unresolved incidents are marked as Pending in the dataset. Looking at both measures gives a clearer picture and helps avoid understating the issue.

D1. Required Core Analysis

Total incidents and distribution by Incident_Type

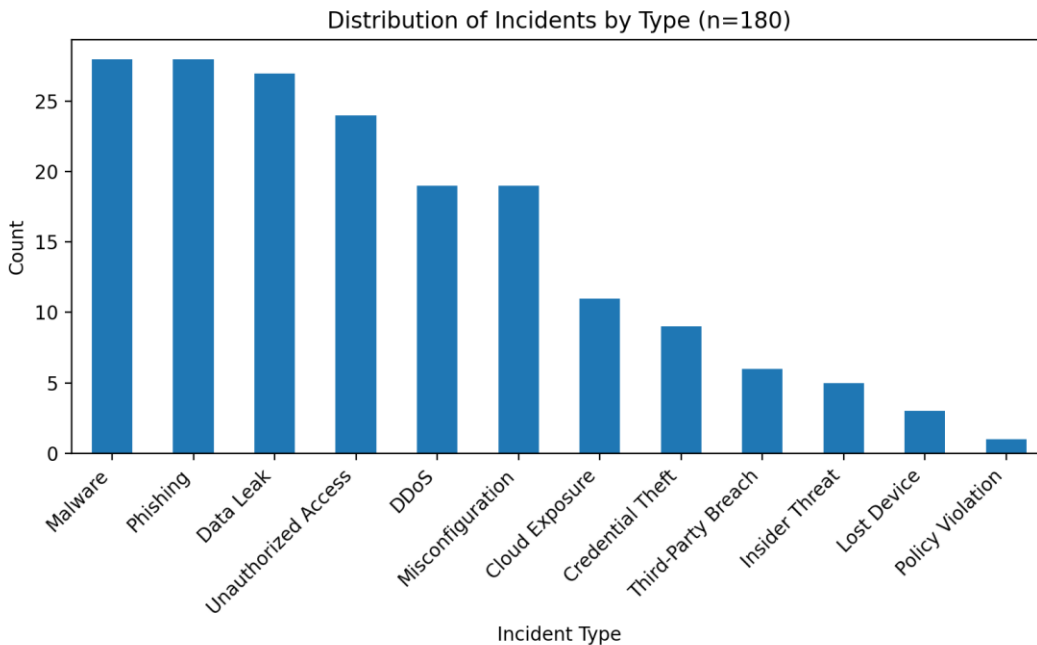
The dataset contains **180 incidents** (INC0001 to INC0180) with a total cost impact of \$10,293,422, an average of \$57,186 per incident.

Incident Type Distribution

Incident Type	Number	Percentage
Malware	28	15.56%
Phishing	28	15.56%
Data Leak	27	15.00%
Unauthorized Access	24	13.33%
DDoS	19	10.56%
Misconfiguration	19	10.56%
Cloud Exposure	11	6.11%
Credential Theft	9	5.00%
Third-Party Breach	6	3.33%
Insider Threat	5	2.78%
Lost Device	3	1.67%

Policy Violation	1	0.56%
TOTAL	180	100.00%

Chart 1: Distribution by Incident Type

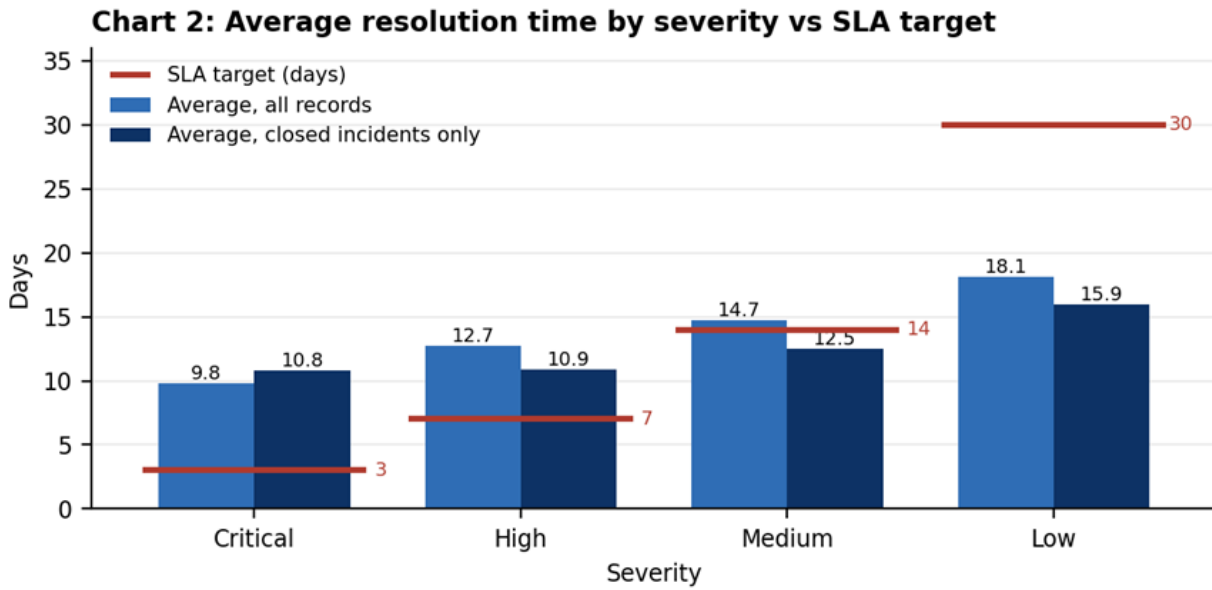


Malware, phishing and data leaks account for 83 of the 180 incidents, which is 46.1% of the total. This shows that a large part of the incident volume comes from a few common incident types.

Average Resolution Time by Severity

Severity	Incidents	Avg days (all records)	Avg days (closed only)	SLA target (days)
Critical	20	9.80	10.82	3
High	53	12.72	10.88	7
Medium	80	14.74	12.53	14
Low	27	18.15	15.94	30

Chart 2: Average Resolution Time by Severity

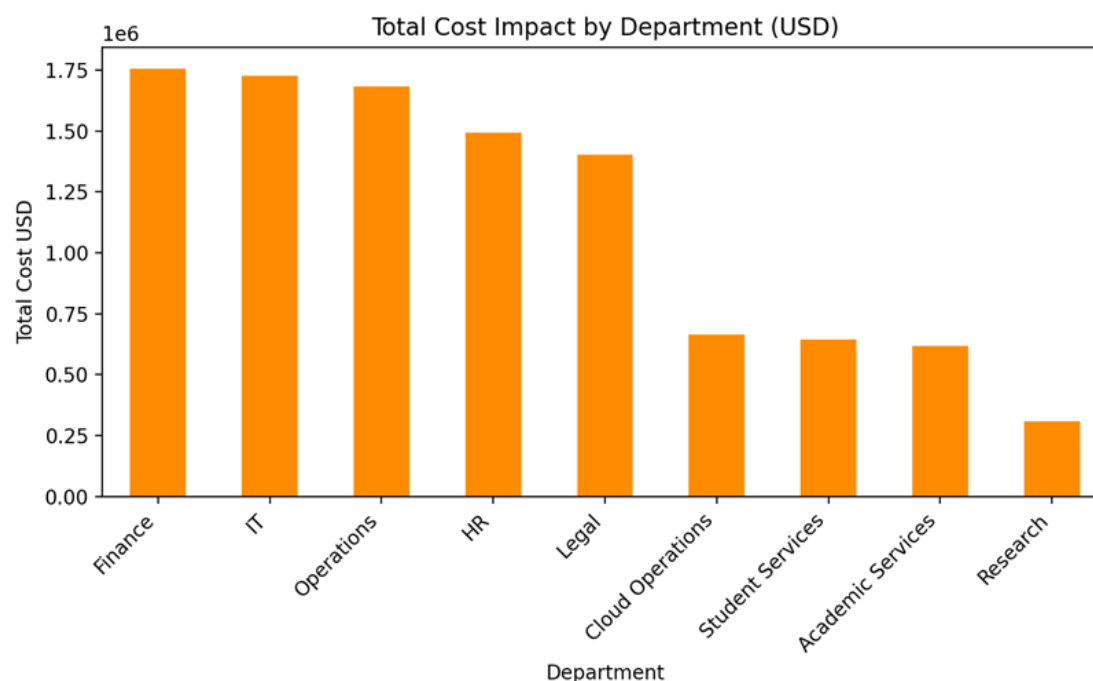


Resolution time increases as severity decreases, from 9.80 days for Critical incidents to 18.15 days for Low incidents. At first, this may seem positive because the more serious incidents are resolved faster. However, the SLA targets show a different picture. Low incidents are well within their 30 day target, but Critical incidents take an average of 9.80 days, or 10.82 days for closed cases, against a 3 day target. Medium incidents are also close to their 14 day target, while High incidents take almost twice as long as their target. This suggests that although serious incidents are being given more attention, they are still not being resolved within the expected time.

Total Cost Impact USD by Department and by Responsible Team

Department	Incidents	Total Cost Impact (USD)	% of total cost
Finance	33	\$1,756,282	17.1%
IT	30	\$1,725,965	16.8%
Operations	32	\$1,682,059	16.3%
HR	25	\$1,493,242	14.5%
Legal	26	\$1,403,244	13.6%
Cloud Operations	10	\$663,410	6.4%
Student Services	8	\$643,730	6.3%
Academic Services	10	\$617,870	6.0%
Research	6	\$307,620	3.0%
TOTAL	180	\$10,293,422	100.0%

Chart 3: Total Cost Impact by Department



Finance recorded the highest total cost at \$1,756,282, followed by IT at \$1,725,965 and Operations at \$1,682,059. The three departments each account for about 16% to 17% of the total cost, while IT is not the department with the highest cost. This shows that the financial impact of cyber incidents affects the whole organisation and should not be treated as only an IT cost.

Total Cost Impact by Responsible Team

Responsible Team	Incidents	Total Cost Impact (USD)	% of total cost
Compliance	42	\$2,836,299	27.6%
DevOps	33	\$2,079,986	20.2%
IT Security	38	\$1,763,143	17.1%
SOC	36	\$1,624,054	15.8%
GRC	11	\$964,680	9.4%
Incident Response	14	\$646,370	6.3%
IAM	3	\$283,670	2.8%

Cloud Security	3	\$95,220	0.9%
----------------	---	----------	------

Compliance has the highest total cost at \$2,836,299, which is 27.6% of the total. This is followed by DevOps at \$2,079,986 and IT Security at \$1,763,143. The high cost recorded for Compliance could be linked to incidents involving regulatory or privacy issues, but the dataset does not provide enough information to confirm this.

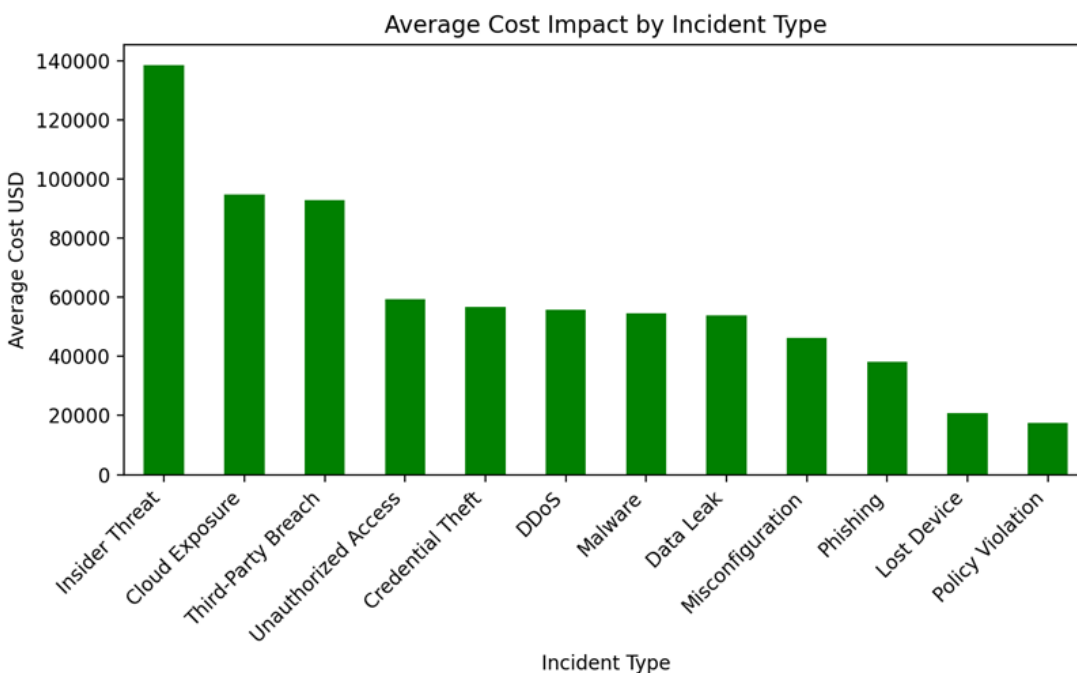
Incident Types with the Highest Average Cost

The three incident types with the highest average cost impact were:

1. **Insider Threat:** \$138,506 average
2. **Cloud Exposure:** \$94,846.36 average
3. **Third Party Breach:** \$92,888.33 average

Insider Threat had only five incidents, but it had the highest average cost. This means that frequency alone should not be used to decide which risks deserve attention. Some less frequent incidents can still create significant financial impact.

Chart 4: Average Cost Impact by Incident Type



Insider Threat has only 5 incidents, but it has the highest average cost at \$138,506, which is about 2.4 times the overall dataset average. Cloud Exposure (\$94,846) and Third Party Breach (\$92,888) also have high average costs. This shows that incident frequency alone should not be

used to decide priorities. For example, Phishing is one of the most common incident types, but its average cost is much lower at \$38,062.

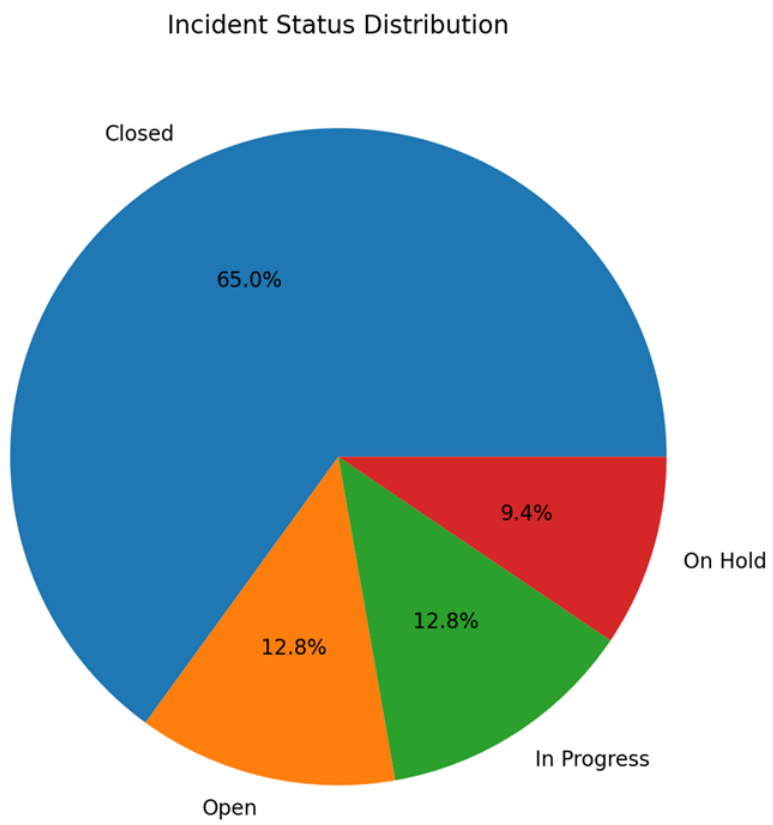
Open and In Progress Incidents

Status	Number	Percentage
Closed	117	65.0%
Open	23	12.8%
In Progress	23	12.8%
On Hold	17	9.4%

There were 46 incidents that were either Open or In Progress. This represents 25.56% of all incidents.

From a governance perspective, this is worth monitoring because unresolved incidents can remain a source of risk. The CISO should therefore have visibility of the incident backlog, especially where incidents have exceeded their expected resolution time.

Chart 5: Incident Status Distribution



D2. Advanced Governance Analysis

SLA Performance by Severity and Responsible Team

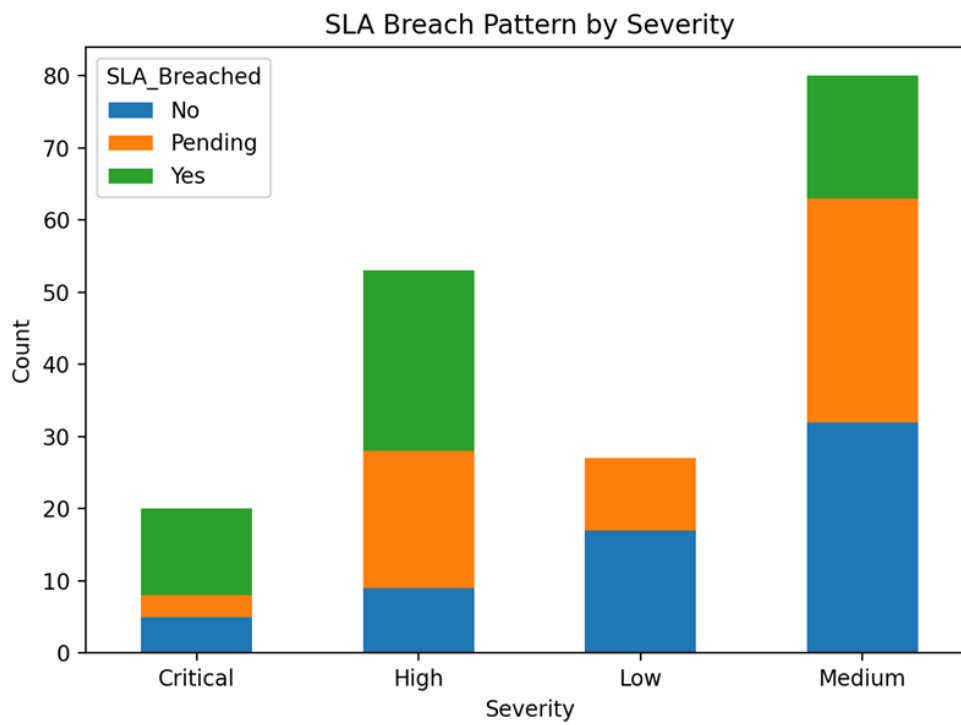
The dataset recorded 54 incidents as SLA breached, 63 as not breached and 63 as pending.

Severity	No	Pending	SLA Breaches	Total Incidents	Breach Rate	Breach Rate (closed only)	Pending already past target
Critical	5	3	12	20	60.00%	70.6%	2
High	9	19	25	53	47.17%	73.5%	17
Medium	32	31	17	80	21.25%	34.7%	22
Low	17	10	0	27	0.00%	0.0%	2

Critical incidents have the highest breach rate across all incidents at 60.00%, with 12 out of 20 incidents breaching their SLA. For closed Critical incidents, the rate is 70.6%, with 12 out of 17 breaching. Closed High incidents also have a high breach rate of 73.5%, with 25 out of 34 breaching.

The pending incidents are also important. Out of the 63 pending incidents, 43 have already been open longer than their SLA target. This includes 17 of the 19 pending High incidents. This means the final breach rates could be higher once these incidents are closed. Overall, the SLA problem is mainly seen in the two highest severity levels, while no Low incident has breached its SLA.

Chart 6:SLA Breach Pattern by Severity



Regulatory Exposure

Privacy is the most common exposure (56 incidents, 31.1%), followed by Contractual (33), Financial Data (14), Operational (12) and Regulatory (10). Education Records (6), Employment Data (4) and Research Data (1) are smaller. 136 incidents (75.6%) carry some regulatory exposure and 44 have none.

Department	Privacy	Contractual	Financial Data	Regulatory	Operational	Other	None
Finance	9	0	14	0	0	0	10
IT	14	8	0	0	0	0	8
HR	9	0	0	0	0	4	12
Legal	10	6	0	10	0	0	0
Cloud Operations	3	4	0	0	3	0	0
Student Services	3	0	0	0	0	4	1
Academic Services	5	0	0	0	0	2	3
Research	3	2	0	0	0	1	0
Operations	0	13	0	0	9	0	10

Each department has a different exposure profile. Finance has all 14 Financial Data exposures, Legal has all 10 Regulatory exposures, and HR has all 4 Employment Data cases. IT has 14 Privacy and 8 Contractual incidents, while Operations has 13 Contractual and 9 Operational incidents. All Legal incidents involve some form of exposure.

Looking at incident types, Phishing has regulatory exposure in 25 of 28 cases, or 89%. DDoS follows at 84%, while Cloud Exposure is at 82%. Malware and Unauthorized Access have lower rates at 68% and 62%. This shows that regulatory risk is spread across different parts of the organisation. Legal cannot manage this risk alone, so Security, Legal, HR and Finance need to work together when an incident involves regulated data.

Third Party Involvement

Measure	Third Party Involved	No third Party
Incidents	43	147
Average cost (USD)	\$73,700	\$52,002
Average cost excluding Third-Party Breach type	\$70,588	\$52,002
Average resolution time (days)	12.74	14.53
Critical incidents	6 (13.95%)	14 (10.22%)
Critical or High incidents	41.9%	40.1%
Escalated to Board / Executive	6 (13.95%)	14 (10.22%)
SLA breach rate (all)	25.6%	31.4%

Third party incidents have a higher average cost than other incidents, at \$73,700 compared with \$52,002. A Welch t test gives $t = 2.76$ and $p \approx 0.0079$, which suggests that the difference is unlikely to be due to chance. The difference is still present when the Third Party Breach type is removed, with an average cost of \$70,588.

Third party incidents also have a slightly higher share of Critical incidents, 13.95% compared with 10.22%, and Board or Executive escalation, also 13.95% compared with 10.22%. However, these figures are based on small counts, 6 compared with 14. They are not slower or worse in terms of SLA. Their average resolution time is 12.74 days compared with 14.53 days for other incidents, while their breach rate is 25.6% compared with 31.4%.

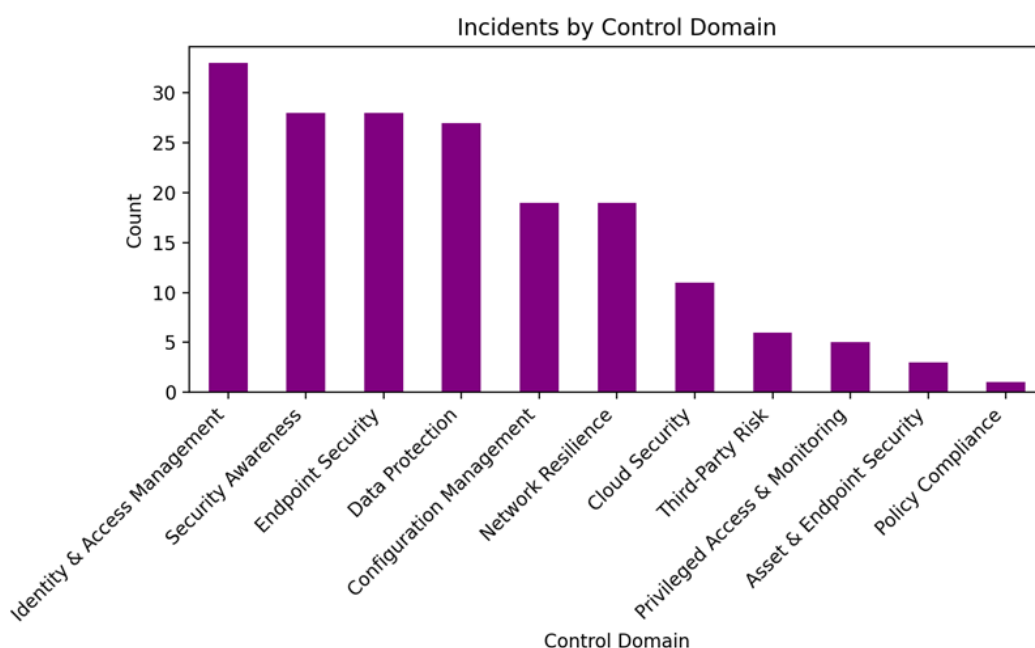
There are two things to keep in mind when interpreting these results. First, this shows an association and does not prove that third parties cause higher costs. All 11 Cloud Exposure incidents and all 6 Third Party Breach incidents involve a third party, and these are already among the more costly incident types. This means incident type could be affecting the result. Second, every Critical incident in the dataset is escalated to the Board or Executive level, so it is difficult to separate the effect of third party involvement from the effect of severity.

Even with these limitations, the findings show why proper third party risk assessment, security requirements in contracts and clear

Control Domain Requiring More Governance Attention

The control domains with the highest incident counts were:

Control Domain	Incidents
Identity and Access Management	33
Security Awareness	28
Endpoint Security	28
Data Protection	27
Configuration Mngement	19
Network Resilience	19



Identity and Access Management had the highest number of incidents with 33 records. Some of the related root causes included compromised credentials, excessive privileges, dormant account misuse, password reuse and MFA fatigue attacks.

Security Awareness also had 28 incidents, which is relevant because phishing and credential related incidents can involve human behaviour as well as technical controls.

Configuration Management also needs attention because it recorded 19 incidents and a 47.37% SLA breach rate. This suggests that management should review configuration standards, change approval, monitoring and remediation timelines.

D3. Three CISO and Board Insights

Insight 1: Critical and High Severity Incidents Are Frequently Missing Their SLA Targets

Critical incidents had a recorded SLA breach rate of 60.00%, with 12 out of 20 incidents breaching the target. High severity incidents had a breach rate of 47.17%, with 25 out of 53 incidents.

The average resolution time for Critical incidents was also 9.80 days, compared with the three day SLA target in the dataset.

From a governance perspective, this means serious incidents may remain open for longer than expected. This can increase the period during which the organisation is exposed to the risk.

Accountable roles: CISO and CRO, with IT Security and DevOps responsible for operational response.

Action: Review the SLA targets and escalation process for Critical and High incidents. A dashboard should be used to monitor these incidents and automatically escalate cases that are approaching their SLA limit.

Success indicator: Reduce the Critical SLA breach rate from 60.00% to below 30% within two reporting cycles.

Insight 2: Insider Threats Are Infrequent but Have High Financial Impact

Insider Threat recorded only 5 incidents, representing 2.78% of all incidents, but it had the highest average cost at \$138,506. The total cost of these incidents was \$692,530.

This shows that an incident does not need to happen frequently to create a serious financial risk. Insider threats can also involve HR, Legal, IT and Security because they may be connected to employee access, termination, disciplinary action and sensitive information.

This also connects with the cross functional failure scenario in Part A, where delayed access removal after an employee's termination created a wider security problem.

Accountable roles: CISO and HR, with Legal consulted where employment or privacy issues are involved.

Action: Strengthen privileged access reviews, introduce better monitoring of unusual user activity and connect the HR termination process with IAM so that access can be removed quickly.

Success indicator: Achieve 100% access removal within two hours of employee termination and reduce the average cost of Insider Threat incidents by 30% within 12 months.

Insight 3: Identity and Access Management Is the Largest Control Domain by Incident Volume

Identity and Access Management recorded 33 incidents, the highest number among the control domains in the dataset. The related root causes include compromised credentials, excessive privileges, dormant account misuse, password reuse and MFA fatigue attacks.

This is important because IAM affects almost every part of the organisation. Weak access controls can lead to unauthorised access, data exposure and misuse of privileged accounts.

It also connects with the MGM Resorts case study in Part C, where attackers used social engineering to gain access through the help desk. This shows why identity verification, access control and strong authentication need proper governance.

Accountable role: CISO, with IT and IAM responsible for implementation and operations. HR should also be involved in joiner, mover and leaver processes.

Action: Implement or strengthen Privileged Access Management, enforce phishing resistant MFA for privileged accounts and sensitive help desk actions, and carry out quarterly reviews of privileged access.

Success indicator: Reduce IAM related incidents by 40% within nine months, achieve 100% MFA coverage for privileged accounts and achieve at least 95% on time manager attestation during quarterly access reviews.

These three findings show that the CISO and Board should not only look at the number of incidents. They also need to consider severity, cost, unresolved incidents, SLA performance and the control areas connected to the incidents. This gives a clearer picture of where governance attention and resources may be needed.

Conclusion

Security governance is not just about tools and technical controls. It also depends on having clear roles, proper accountability and good communication across the organisation.

Part A showed how a RACI matrix and a few segregation of duties controls can make responsibilities clearer without slowing down the business. It also showed how an escalation path with clear timelines can help prevent important risks from getting stuck at the operational level. Part B showed that the CISO role now involves more than technical management. The CISO also has a role in managing business risk, and the reporting structure and access to the Board can affect how well the role is carried out. Part C, which looked at the Change Healthcare incident, showed how weak control enforcement, inherited systems, dependence on one service and unclear notification responsibilities can create a governance problem that goes beyond IT.

Part D provided evidence from the simulated dataset. Insider Threat has the highest average cost per incident, Critical and High incidents are more likely to miss their SLA targets, and Identity and Access Management has both the highest number of incidents and the highest total cost. Based on these findings, my main priorities would be to strengthen IAM, improve SLA monitoring and encourage better collaboration between Security, HR, IT, Legal, Finance and Risk. Each recommendation has an owner and a clear measure, so management and the Board can track whether the changes are actually working.

References

Federal Republic of Nigeria (2023) Nigeria Data Protection Act 2023. Nigeria Data Protection Commission. <https://ndpc.gov.ng/>

Heidrick & Struggles (2022) 2022 Global Chief Information Security Officer (CISO) Survey. <https://www.heidrick.com/en/insights/compensation-trends/2022-global-chief-information-security-officer-ciso-survey>

Heidrick & Struggles (2025) 2025 Global Chief Information Security Officer Compensation Survey. <https://www.heidrick.com/en/insights/cybersecurity/2025-global-chief-information-security-officer-compensation-survey>

ICDFA (2026) GRC102 Week 3 NDPC Security Incidents Enhanced Workbook. Simulated academic dataset, Incident_Data sheet. [GRC102 W3 ANALYSIS - MERCY AJAYI C11-26-CGRCE-17219.xlsx](#)

International Organization for Standardization (2022) ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection: Information security management systems: Requirements. Geneva: ISO.

National Institute of Standards and Technology (2024) The NIST Cybersecurity Framework (CSF) 2.0. NIST Cybersecurity White Paper 29. <https://csrc.nist.gov/pubs/cswp/29/the-nist-cybersecurity-framework-csf-20/final>

U.S. Department of Health and Human Services, Office for Civil Rights (2024) Change Healthcare Cybersecurity Incident Frequently Asked Questions. <https://www.hhs.gov/hipaa/for-professionals/special-topics/change-healthcare-cybersecurity-incident-frequently-asked-questions/index.html>

U.S. Department of Justice, U.S. Attorney's Office, Northern District of California (2022a). Former Chief Security Officer of Uber Convicted of Federal Charges for Covering Up Data Breach Involving Millions of Uber User Records. <https://www.justice.gov/usao-ndca/pr/former-chief-security-officer-uber-convicted-federal-charges-covering-data-breach>

U.S. Department of Justice, U.S. Attorney's Office, Northern District of California (2022b) Non-Prosecution Agreement with Uber Technologies, Inc. <https://www.justice.gov/media/1233736/dl>

U.S. Department of Justice, U.S. Attorney's Office, Northern District of California (2023) Former Chief Security Officer of Uber Sentenced to Three Years' Probation for Covering Up Data Breach Involving Millions of Uber User Records. <https://www.justice.gov/usao-ndca/pr/former-chief-security-officer-uber-sentenced-three-years-probation-covering-data>

U.S. Securities and Exchange Commission (2023) Cybersecurity Risk Management, Strategy, Governance, and Incident Disclosure. <https://www.sec.gov/rules-regulations/2023/07/s7-09-22>

U.S. Senate Committee on Finance (2024a) *Hacking America's Health Care: Assessing the Change Healthcare Cyber Attack and What's Next*. Hearing transcript, 1 May. <https://www.congress.gov/118/chrg/CHRG-118shrg63595/CHRG-118shrg63595.pdf>

U.S. Senate Committee on Finance (2024b) *Testimony of Andrew Witty, Chief Executive Officer, UnitedHealth Group*, 1 May. <https://www.finance.senate.gov/download/0501-witty-testimony>

U.S. Senate Committee on Finance (2024c) *Responses to Questions for the Record for Andrew Witty*. <https://www.finance.senate.gov/download/responses-for-questions-for-the-record-to-andrew-witty>

U.S. Senate Committee on Finance (2024d) *Wyden Hearing Statement on Change Healthcare Cyberattack and UnitedHealth Group's Response*, 1 May. <https://www.finance.senate.gov/chairmans-news/wyden-hearing-statement-on-change-healthcare-cyberattack-and-unitedhealth-groups-response>

UnitedHealth Group (2022) *Optum and Change Healthcare Complete Combination*. Press release, 3 October.

<https://www.unitedhealthgroup.com/newsroom/2022/2022-10-3-optum-change-healthcare-combination.html>

UnitedHealth Group (2024) *Form 8-K, 21 February 2024: Material Cybersecurity Incident*. U.S. Securities and Exchange Commission. <https://www.sec.gov/Archives/edgar/data/731766/000073176624000045/unh-20240221.htm>

UnitedHealth Group (2025) *Form 10-K for the year ended 31 December 2024*. U.S. Securities and Exchange Commission. <https://www.sec.gov/Archives/edgar/data/731766/000073176625000063/unh-20241231.htm>